

Intrusion Detection

Module VII

Intruders

- significant issue for networked systems is hostile or unwanted access
- either via network or local
- can identify classes of intruders:
 - **Masquerader** → An individual who is not authorized to use the computer and who penetrates a system's access controls to exploit a legitimate user's account
 - **Misfeasor** → A legitimate user who accesses data, programs, or resources for which such access is not authorized, or who is authorized for such access but misuses his or her privileges
 - **Clandestine user** → An individual who seizes supervisory control of the system and uses this control to evade auditing and access controls or to suppress audit collection
- varying levels of competence

Examples of Intrusion

- remote root compromise
- web server defacement
- guessing / cracking passwords
- copying viewing sensitive data / databases
- running a packet sniffer
- distributing pirated software
- using an unsecured modem to access net
- impersonating a user to reset password
- using an unattended workstation

Intrusion Detection

- inevitably will have security failures
- so need also to detect intrusions so can
 - block if detected quickly
 - act as deterrent
 - collect info to improve security
- assume intruder will behave differently to a legitimate user
 - but will have imperfect distinction between

Intrusion Detection vs. Extrusion Detection

- Intrusion detection is mostly concerned about the identification of incoming attacks (intrusion attempts)
- Extrusion detection systems try to prevent attacks from being launched in the first place

Hackers

- motivated by thrill of access and status
 - hacking community a strong meritocracy
 - status is determined by level of competence
- benign intruders might be tolerable
 - do consume resources and may slow performance
 - can't know in advance whether benign or malign
- IDS / IPS / VPNs can help counter
- awareness led to establishment of CERTs
 - collect / disseminate vulnerability info / responses

Hacker Behavior Example

1. select target using IP lookup tools
2. map network for accessible services
3. identify potentially vulnerable services
4. brute force (guess) passwords
5. install remote administration tool
6. wait for admin to log on and capture password
7. use password to access remainder of network

Criminal Enterprise

- organized groups of hackers now a threat
 - corporation / government / loosely affiliated gangs
 - typically young
 - often Eastern European or Russian hackers
 - often target credit cards on e-commerce server
- criminal hackers usually have specific targets
- once penetrated act quickly and get out
- IDS / IPS help but less effective
- sensitive data needs strong protection

Criminal Enterprise Behavior

1. act quickly and precisely to make their activities harder to detect
2. exploit perimeter via vulnerable ports
3. use trojan horses (hidden software) to leave back doors for re-entry
4. use sniffers to capture passwords
5. do not stick around until noticed
6. make few or no mistakes

Insider Attacks

- among most difficult to detect and prevent
- employees have access & systems knowledge
- may be motivated by revenge / entitlement
 - when employment terminated
 - taking customer data when move to competitor
- IDS / IPS may help but also need:
 - least privilege, monitor logs, strong authentication, termination process to block access & mirror data

Insider Behavior Example

1. create network accounts for themselves and their friends
2. access accounts and applications they wouldn't normally use for their daily jobs
3. e-mail former and prospective employers
4. conduct furtive instant-messaging chats
5. visit web sites that cater to disgruntled employees, such as [f'dcompany.com](#)
6. perform large downloads and file copying
7. access the network during off hours

Intrusion Techniques

- aim to gain access and/or increase privileges on a system
- often use system / software vulnerabilities
- key goal often is to acquire passwords
 - so then exercise access rights of owner
- basic attack methodology
 - target acquisition and information gathering
 - initial access
 - privilege escalation
 - covering tracks

Password Guessing

- one of the most common attacks
- attacker knows a login (from email/web page etc)
- then attempts to guess password for it
 - defaults, short passwords, common word searches
 - user info (variations on names, birthday, phone, common words/interests)
 - exhaustively searching all possible passwords
- check by login or against stolen password file
- success depends on password chosen by user
- surveys show many users choose poorly

Password Capture

- another attack involves password capture
 - watching over shoulder as password is entered
 - using a trojan horse program to collect
 - monitoring an insecure network login
 - eg. telnet, FTP, web, email
 - extracting recorded info after successful login (web history/cache, last number dialed etc)
- using valid login/password can impersonate user
- users need to be educated to use suitable precautions/countermeasures

Approaches to Intrusion Detection

- statistical anomaly detection
 - attempts to define normal/expected behavior
 - threshold
 - profile based
- rule-based detection
 - attempts to define proper behavior
 - anomaly
 - penetration identification

Audit Records

- fundamental tool for intrusion detection
- native audit records
 - part of all common multi-user O/S
 - already present for use
 - may not have info wanted in desired form
- detection-specific audit records
 - created specifically to collect wanted info
 - at cost of additional overhead on system

Audit Record Analysis

- foundation of statistical approaches
- analyze records to get metrics over time
 - counter, gauge, interval timer, resource use
- use various tests on these to determine if current behavior is acceptable
 - mean & standard deviation, multivariate, markov process, time series, operational
- key advantage is no prior knowledge used

Statistical Anomaly Detection

- threshold detection
 - count occurrences of specific event over time
 - if exceed reasonable value assume intrusion
 - alone is a crude & ineffective detector
- profile based
 - characterize past behavior of users
 - detect significant deviations from this
 - profile usually multi-parameter

Rule-Based Intrusion Detection

- observe events on system & apply rules to decide if activity is suspicious or not
- rule-based anomaly detection
 - analyze historical audit records to identify usage patterns & auto-generate rules for them
 - then observe current behavior & match against rules to see if conforms
 - like statistical anomaly detection does not require prior knowledge of security flaws

Rule-Based Intrusion Detection ... Contd

- rule-based penetration identification
 - uses expert systems technology
 - with rules identifying known penetration, weakness patterns, or suspicious behavior
 - compare audit records or states against rules
 - rules usually machine & O/S specific
 - rules are generated by experts who interview & codify knowledge of security admins
 - quality depends on how well this is done

Honeypots

- decoy systems to lure attackers
 - away from accessing critical systems
 - to collect information of their activities
 - to encourage attacker to stay on system so administrator can respond
- are filled with fabricated information
- instrumented to collect detailed information on attackers activities
- single or multiple networked systems